Eco-Inversión CR – Flujos críticos

Owner: Diana
Reviewer:
Contributors:
Date Generated: Sun Nov 08 2026

Executive Summary

High level system description

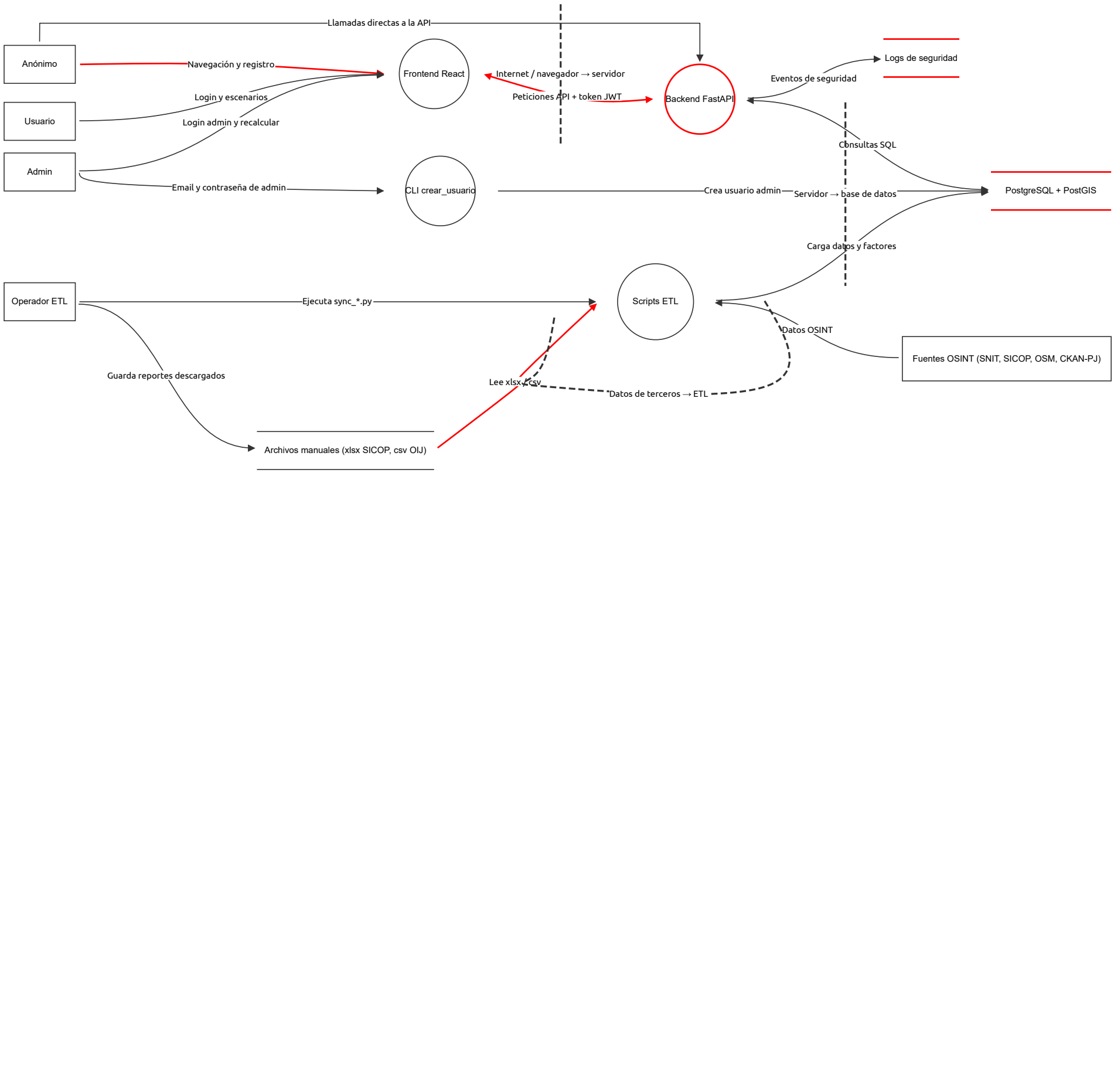
Modelo de amenazas STRIDE de los flujos F1 (autenticación), F2 (recalcular índice) y F3 (escenarios privados) definidos en docs/autenticacion.md.

Summary

Total Threats	10
Total Mitigated	0
Total Open	10
Open / Critical Severity	0
Open / High Severity	1
Open / Medium Severity	7
Open / Low Severity	2

Flujos F1–F3

DFD de los flujos críticos: actores, backend, base de datos, ETL y fuentes OSINT externas, con sus fronteras de confianza.



Flujos F1–F3

Backend FastAPI (Process)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
3	T-03 Token JWT falsificado si se filtra la clave secreta	Spoofing	Medium	Open	6 (P2 × I3)	Recurso: proceso Backend FastAPI, que valida los tokens JWT con una clave secreta guardada en variables de entorno. Si esa clave se filtra (repositorio, .env compartido, logs), cualquiera puede firmar un token que el backend acepta como válido. Impacto: el atacante se hace pasar por cualquier usuario, incluso por un admin (el rol va dentro del token), y puede recalcular el índice o ver escenarios privados. También es una elevación de privilegios (E). Prioridad: Probabilidad 2 (primero tiene que filtrarse la clave) × Impacto 3 (control total como admin) = 6 → Media.	
4	T-04 Credential stuffing contra el login	Spoofing	Medium	Open	6 (P3 × I2)	Recurso: proceso Backend FastAPI, endpoint POST /auth/login. El bloqueo después de varios intentos fallidos es por cuenta, pero no hay límite de intentos por IP. Impacto: un atacante prueba listas de correos y contraseñas filtradas de otros sitios (probando pocas veces cada cuenta para no activar el bloqueo) y entra a las cuentas de usuarios que reutilizan contraseñas; puede ver o borrar sus escenarios privados. Prioridad: Probabilidad 3 (ataque automatizado, barato y muy común) × Impacto 2 (afecta cuentas de usuario normales, no de admin, que se crea solo por CLI) = 6 → Media.	
5	T-06 Saturación del backend por falta de límite de peticiones	Denial of service	Medium	Open	4 (P2 × I2)	Recurso: proceso Backend FastAPI. No hay un límite global de peticiones por IP, y los endpoints que devuelven GeoJSON de mapas son pesados para el servidor y la base de datos. Impacto: muchas peticiones seguidas a esos endpoints pueden dejar lenta o caída la aplicación para todos los usuarios. Prioridad: Probabilidad 2 (fácil de hacer, pero el proyecto no es un objetivo muy atractivo) × Impacto 2 (caída temporal, sin pérdida de datos) = 4 → Media.	
6	T-05 Bloqueo deliberado de cuentas ajenas	Denial of service	Medium	Open	6 (P3 × I2)	Recurso: proceso Backend FastAPI, endpoint POST /auth/login. Después de varios intentos fallidos la cuenta se bloquea temporalmente, sin importar desde dónde vienen los intentos. Impacto: un atacante que conoce el correo de una víctima falla el login a propósito y deja a esa persona sin acceso a sus escenarios; repetido sobre muchas cuentas, deja la aplicación inservible para los usuarios. Prioridad: Probabilidad 3 (solo necesita el correo de la víctima y un script) × Impacto 2 (pérdida de acceso temporal, sin pérdida de datos) = 6 → Media.	
8	T-08 Token robado sigue válido porque no se puede revocar	Spoofing	Medium	Open	4 (P2 × I2)	Recurso: proceso Backend FastAPI. Los JWT no se guardan en el servidor, así que no hay forma de invalidarlos antes de que expiren (cerrar sesión solo borra el token en el navegador). Impacto: si alguien roba un token (por ejemplo desde el navegador o un equipo compartido), puede usarlo y hacerse pasar por el usuario hasta que el token expire, aunque la víctima ya haya cerrado sesión o cambiado su contraseña. Prioridad: Probabilidad 2 (primero hay que robar el token) × Impacto 2 (acceso limitado al tiempo de vida del token) = 4 → Media.	

PostgreSQL + PostGIS (Store)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
1	T-01 Base de datos expuesta con contraseña por defecto	Information disclosure	High	Open	9 (P3 × I3)	Recurso: PostgreSQL + PostGIS. En docker-compose.yml el puerto 5432 está publicado y POSTGRES_PASSWORD tiene "changeme" por defecto. Impacto: un atacante podría leer o cambiar usuarios (hashes de contraseñas), escenarios privados y el índice de viabilidad. Prioridad: Probabilidad 3 (puerto abierto + contraseña conocida, fácil de encontrar con un escaneo) × Impacto 3 (toda la base de datos) = 9 → Alta.	

Navegación y registro (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
10	T-10 Enumeración de cuentas en el registro	Information disclosure	Low	Open	3 (P3 × I1)	Recurso: flujo "Navegación y registro", endpoint POST /auth/registro. Si el correo ya existe, la API responde 409 (conflicto), distinto a cuando el registro funciona. Impacto: un atacante puede averiguar qué correos tienen cuenta y usar esa lista para credential stuffing (T-04) o para bloquear cuentas (T-05). Prioridad: Probabilidad 3 (basta con probar correos en el formulario) × Impacto 1 (solo revela que la cuenta existe, no datos) = 3 → Baja.	

Peticiones API + token JWT (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
9	T-09 Acceso a escenarios de otro usuario (IDOR)	Information disclosure	Low	Open	3 (P1 × I3)	Recurso: flujo "Peticiones API + token JWT", rutas /escenarios/{id} (ver, editar, borrar y exportar CSV). Un usuario autenticado podría cambiar el id en la URL para intentar acceder a escenarios de otra persona (IDOR). Impacto: lectura o modificación de escenarios privados de otros usuarios. Prioridad: Probabilidad 1 (el backend ya verifica que el escenario pertenezca al usuario del token; el riesgo queda si un endpoint nuevo olvida esa verificación) × Impacto 3 (datos privados de terceros) = 3 → Baja.	

Logs de seguridad (Store)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
7	T-07 Logs sin integridad ni retención	Repudiation	Medium	Open	4 (P2 × I2)	Recurso: almacén Logs de seguridad. Los eventos de seguridad (logins, bloqueos, recálculo del índice) se escriben en la salida estándar (stdout) del contenedor, sin protección de integridad ni política de retención. Impacto: quien tenga acceso al servidor puede borrar o alterar los registros, y al reiniciar o recrear el contenedor se pueden perder; después no se puede demostrar quién hizo una acción (por ejemplo, quién recalculó el índice). Prioridad: Probabilidad 2 (requiere acceso al servidor o que se recree el contenedor) × Impacto 2 (se pierde la trazabilidad, no los datos del negocio) = 4 → Media.	

Lee xlsx / csv (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
2	T-02 Datos manipulados en la entrada del ETL	Tampering	Medium	Open	6 (P2 × I3)	Recurso: flujo "Lee xlsx / csv" (archivos SICOP y OIJ descargados a mano) y también "Datos OSINT". Los scripts ETL cargan a la base de datos lo que leen, sin verificar la integridad del archivo (hash o firma) ni su origen. Impacto: datos falsos o alterados cambian los factores y el índice de viabilidad, y los usuarios tomarían decisiones de inversión con información incorrecta. Prioridad: Probabilidad 2 (requiere alterar un archivo descargado o una fuente externa; no es trivial, pero nada lo detecta) × Impacto 3 (afecta el resultado principal del sistema) = 6 → Media.	